

Defense Questions & Answers

Intelligent Platform for Supervision and Automated Security

Prepared speaker answers for the project defense: architecture, components, SOC logic, AI layer, security choices, testing, limitations, and future work.

Main message to keep in mind

Key idea: This platform is not only a dashboard. It is an end-to-end SOC workflow: detection, enrichment, correlation, investigation, AI assistance, approval, remediation, verification, and archiving.

Based on the uploaded presentation slides.

How to Use This Document

This document prepares you for the most likely jury questions about your SOC/SOAR platform presentation. The goal is not to memorize every word, but to understand the structure of the answer.

Main message to keep in mind:

Key idea: This platform is not only a dashboard. It is an end-to-end SOC workflow: detection, enrichment, correlation, investigation, AI assistance, approval, remediation, verification, and archiving.

Use these rules during the defense:

- For technical questions, explain the component role, why it is used, and how it connects to the global workflow.
- For AI questions, always say that AI assists the analyst but does not execute blindly.
- For security questions, mention internal Elasticsearch, VPC/security groups, authentication/TLS, approval, audit, and verification.
- For tricky questions, stay honest: explain the current version, limitations, and how it can evolve.

1. General Project Questions

Q1. What is the main goal of your project?

The main goal is to build an intelligent SOC platform that centralizes monitoring and security data, detects suspicious activity, correlates alerts into incidents, assists analysts using AI, and supports controlled automated remediation using Ansible.

So the project is not only a dashboard. It covers the full SOC workflow: detection, enrichment, correlation, investigation, AI analysis, approval, remediation, verification, and archiving.

Q2. What problem does your platform solve?

The problem is that security tools are often fragmented. Suricata, Wazuh, Falco, system metrics, and logs can all generate useful data, but they are usually analyzed separately.

This creates alert fatigue and makes incident response slower. My platform centralizes this data, normalizes it, enriches it, correlates related alerts, and helps the analyst understand and respond faster.

Q3. What is the added value of your project compared to a classic SIEM?

A classic SIEM mainly collects, stores, searches, and visualizes logs. My project goes further by adding an intelligence layer.

The backend transforms raw alerts into normalized alerts, correlates them into incidents, creates investigations, generates AI explanations and Ansible playbooks, then uses an approval workflow before execution.

So the added value is the move from passive monitoring to assisted and controlled SOC operations.

Q4. Can you summarize your project in one sentence?

My project transforms raw security and monitoring data into actionable SOC intelligence, then supports controlled response through AI-assisted investigation and Ansible remediation.

2. Architecture Questions

Q5. Can you explain the global architecture?

The architecture has three phases.

Phase 1 is the monitoring foundation, with tools like Suricata, Wazuh, Falco, Telegraf, Filebeat, Elasticsearch, and Kibana.

Phase 2 is the Huawei Cloud infrastructure, where the platform is deployed on an ECS VM inside a secured VPC with security groups and controlled access.

Phase 3 is the backend intelligence layer, which reads alerts from Elasticsearch, normalizes and enriches them, correlates them into incidents, creates investigations, sends context to AI, generates remediation playbooks, and manages approval and execution.

Q6. Why did you divide the project into three phases?

I divided it into three phases to build the platform progressively.

First, I needed visibility, so I built the monitoring foundation. Second, I needed a real deployment environment, so I deployed the platform on Huawei Cloud. Third, I added intelligence and automation through the backend.

This makes the project structured, testable, and easier to validate step by step.

Q7. What is the data flow in your platform?

The data flow starts from security sources such as system logs, Suricata, Wazuh, Falco, and Telegraf.

These events are collected by Filebeat, Falcosidekick, or Telegraf and sent to Elasticsearch. Kibana visualizes them.

Then the backend reads from Elasticsearch, normalizes alerts, enriches them, stores them locally, correlates them into incidents, creates investigations, sends context to AI, generates playbooks, and finally manages approval, execution, verification, and archiving.

3. Phase 1 - Monitoring Foundation

Q8. Why did you use Suricata?

Suricata is used for network intrusion detection. It analyzes network traffic and detects suspicious activity such as port scans, brute force attempts, malware traffic, command-and-control communication, and known attack signatures.

In my architecture, Suricata gives visibility at the network layer.

Q9. Why did you use Wazuh?

Wazuh provides host-based intrusion detection. It monitors authentication logs, file integrity, system events, vulnerabilities, and suspicious host behavior.

So while Suricata monitors the network, Wazuh monitors what happens on the machine itself.

Q10. Why did you use Falco?

Falco is used for runtime security detection. It detects suspicious behavior at the system or container level, such as unexpected shell execution, sensitive file access, or abnormal process activity.

It adds runtime visibility, especially useful for Linux and containerized environments.

Q11. Why did you use Telegraf?

Telegraf collects infrastructure metrics such as CPU, RAM, disk, network, load, processes, and TCP connections.

This is important because SOC operations are not only about attacks. Performance anomalies can also indicate problems, misconfigurations, or even security incidents.

Q12. Why Elasticsearch and Kibana?

Elasticsearch is used as the central storage and indexing engine for logs, alerts, and metrics. It allows fast search and querying.

Kibana is used for visualization, dashboards, and event exploration. Together, they form the SIEM visualization core of the platform.

Q13. What is the role of Filebeat?

Filebeat is the log shipper. It reads log files from sources like system logs, Suricata eve.json, and Wazuh alerts, then sends them to Elasticsearch.

Its role is to transport logs from the machine to the central storage.

Q14. What is Falcosidekick?

Falcosidekick is used to receive alerts from Falco and forward them to another destination, in this case Elasticsearch.

It acts as a bridge between Falco runtime detection and the centralized logging system.

4. Phase 2 - Cloud Infrastructure

Q15. Why did you deploy on Huawei Cloud?

Huawei Cloud provides the real infrastructure environment for the platform. Instead of keeping the project only as a local lab, deployment on Huawei Cloud shows that the solution can run in a real cloud context with compute resources, network isolation, security groups, and public access control.

Q16. Why did you use an ECS VM?

I used an ECS VM because the stack contains several services that need strong resources, such as Elasticsearch, Kibana, Wazuh, Suricata, Falco, Telegraf, Docker, and the backend.

The ECS VM provides enough CPU and RAM to host and test the complete SOC stack.

Q17. Why do you need 64 vCPU and 128 GB RAM?

The platform processes logs, alerts, metrics, and security events. Elasticsearch and Wazuh can consume significant memory and CPU, especially with high ingestion volume.

The 64 vCPU and 128 GB RAM give enough capacity for indexing, searching, dashboards, backend processing, and future scalability tests.

Q18. What is the role of the VPC?

The VPC isolates the SOC environment from the public internet and other networks. It creates a private network where internal services can communicate securely.

This is important because SOC data is sensitive and should not be exposed unnecessarily.

Q19. What is the role of Security Groups?

Security Groups act like cloud firewall rules. They control which ports are allowed and from which sources.

For example, SSH and Kibana should only be accessible from authorized IPs, and Elasticsearch should remain internal.

Q20. Should Elasticsearch be publicly exposed?

No. Elasticsearch should not be publicly exposed because it contains sensitive logs, alerts, and security data.

It must remain internal. Access should be restricted to backend services and authorized administrators only. If remote access is needed, it should go through VPN, SSH tunnel, or private network access.

This also corrects the slide mistake where Elasticsearch exposure was mentioned incorrectly.

5. Phase 3 - Backend Intelligence

Q21. What is the role of the backend intelligence layer?

The backend intelligence layer transforms raw security data into operational SOC workflows.

It reads alerts from Elasticsearch, normalizes them, enriches them, removes duplicates, correlates related alerts into incidents, creates investigations, sends context to AI, generates playbooks, manages approval, executes actions, verifies results, and archives the lifecycle.

Q22. Why do you normalize alerts?

Each tool generates alerts in a different format. Suricata, Wazuh, Falco, and Telegraf do not use the same fields.

Normalization transforms all these alerts into a common model with fields like source, severity, title, category, IPs, hostname, IOCs, MITRE techniques, and metadata.

This makes correlation and analysis easier.

Q23. What is enrichment?

Enrichment means adding useful context to an alert.

For example, if an alert contains an IP address, the backend can add GeoIP information. If the alert matches an attack behavior, the backend can add MITRE ATT&CK techniques.

This helps the analyst understand the alert faster.

Q24. Why do you need deduplication?

Security tools can generate the same alert many times. Without deduplication, the analyst would see repeated alerts and suffer from alert fatigue.

Deduplication groups repeated alerts and keeps an occurrence count instead of displaying the same event many times.

Q25. What is the difference between an alert and an incident?

An alert is a single security event generated by one source, for example a Suricata port scan alert.

An incident is a higher-level case created by correlating one or more related alerts. For example, a port scan, SSH brute force, and suspicious shell activity from the same source can become one incident.

So alerts are raw signals, while incidents are meaningful security cases.

Q26. What is an investigation?

An investigation is the detailed analysis of an incident.

It contains the timeline of related alerts, IOCs, IPs, ports, services, MITRE techniques, risk score, AI summary, attack narrative, and proposed remediation.

So the investigation is the bridge between incident detection and response.

Q27. How does incident correlation work?

The correlation engine compares alerts using shared indicators and context.

It checks if alerts share the same source IP, same target host, same container, same MITRE technique, same attack pattern, or happen in the same time window.

If multiple alerts are related, they are grouped into one incident with stronger context and higher confidence.

Q28. Can you give an example of correlation?

Yes. Suppose Suricata detects a port scan from an IP address. Then Wazuh detects SSH brute force from the same IP. Later, Falco detects suspicious shell activity on the target machine.

Instead of treating these as three separate alerts, the platform correlates them into one stronger incident: a possible intrusion attempt progressing from reconnaissance to access attempt and suspicious runtime activity.

6. AI Questions

Q29. Why did you add AI to the platform?

I added AI to help analysts understand incidents faster.

The AI can summarize the investigation, explain the attack chain, evaluate risk, and generate a remediation playbook. This reduces manual analysis time and makes technical alerts easier to understand.

But AI is used as an assistant, not as an uncontrolled decision-maker.

Q30. Does the AI execute actions directly?

No. The AI does not execute actions directly.

It generates analysis and suggested playbooks, but the backend validates the output, checks the YAML syntax, applies safety rules, and requires approval before execution.

The principle is controlled automation, not blind automation.

Q31. Which AI providers does your platform support?

The platform supports multiple LLM providers, including local Ollama, Google Gemini, OpenRouter, and NVIDIA NIM.

This multi-provider approach gives flexibility. For example, Ollama can be used locally for privacy, while cloud providers can be used for stronger models if needed.

Q32. Why use Ollama locally?

Ollama allows running the LLM locally. This is useful for privacy and control because sensitive SOC data does not necessarily need to be sent to an external AI provider.

It also helps test the AI layer without depending completely on cloud APIs.

Q33. What are the risks of using AI in cybersecurity?

There are several risks: hallucination, wrong remediation suggestions, unsafe commands, or misunderstanding context.

That is why my platform does not trust AI blindly. It uses validation, approval workflows, whitelist protection, execution checks, and audit logs.

AI assists the analyst, but final control remains with the platform and the human operator.

7. Ansible and Remediation Questions

Q34. Why did you use Ansible?

Ansible is used because it is agentless, widely used, and suitable for automation through SSH.

It allows the platform to generate and execute remediation actions such as checking services, blocking an IP, collecting forensic information, verifying system state, or applying hardening actions.

Q35. What is a playbook?

A playbook is a YAML file that defines automation tasks for Ansible.

In this project, the AI can generate playbooks based on the incident context, and the backend validates them before approval and execution.

Q36. What happens before executing a playbook?

Before execution, the backend validates the YAML syntax, checks SSH connectivity, verifies that the target is allowed, applies whitelist protection, and requires approval depending on risk level.

Only after these checks can the playbook be executed.

Q37. What happens after executing a playbook?

After execution, the backend stores execution logs and verifies the result.

For example, if a playbook blocks an IP, the system should verify that the firewall rule was applied. Then the action is archived for traceability.

Q38. Why is approval important?

Approval is important because remediation actions can affect production systems.

For example, blocking an IP, restarting a service, or changing firewall rules can have business impact. The approval workflow ensures that actions are controlled, audited, and validated before execution.

8. Security Questions

Q39. How do you secure the platform?

The platform is secured at multiple levels.

At the cloud level, the VPC isolates the environment and security groups restrict access. At the service level, Elasticsearch should remain internal, and access to Kibana and SSH should be restricted.

At the backend level, actions are logged, playbooks are validated, and remediation requires approval. At the communication level, TLS and authentication should be used.

Q40. What is the most sensitive component?

Elasticsearch is one of the most sensitive components because it stores logs, alerts, metrics, and security data.

The backend and AI context can also contain sensitive incident information. That is why access control, private networking, and audit logs are important.

Q41. How do you prevent dangerous automation?

The platform prevents dangerous automation using several controls: YAML validation, approval workflow, target whitelist, SSH connectivity check, execution logging, and result verification.

High-risk actions can be blocked or require manual approval.

9. Testing Questions

Q42. How did you test the platform?

The platform is tested at several levels.

Unit tests validate alert mappers, enrichment, correlation logic, YAML parsing, and playbook generation.

Integration tests validate the complete flow from Elasticsearch to the backend, SQLite, API, and WebSocket.

Functional tests simulate attacks such as brute force, port scans, and malware-like behavior.

Performance and security tests validate ingestion load, dashboard latency, firewall rules, TLS, authentication, and audit trails.

Q43. How do you know the correlation works?

To validate correlation, I test scenarios where multiple alerts share common indicators, such as the same source IP, same target host, same MITRE technique, or close time window.

If the platform groups them into the correct incident and assigns meaningful context, then the correlation logic is working.

Q44. How do you test the AI output?

The AI output is tested by checking if the generated summary is coherent, if the risk evaluation matches the incident context, and if the generated playbook is valid YAML.

The playbook is not trusted directly. It must pass syntax validation and approval before execution.

10. Methodology Questions

Q45. What methodology did you use?

I used an agile iterative methodology.

The project was divided into three main phases, and each phase produced an operational deliverable: first monitoring, then cloud infrastructure, then backend intelligence.

I also used continuous documentation, testing, and code review during development.

Q46. Why is the methodology iterative?

Because a SOC platform is complex and includes many components. Building everything at once would be risky.

The iterative approach allowed me to validate each layer before moving to the next one: first data collection, then deployment, then intelligence and automation.

11. Limitations and Future Work

Q47. What are the current limitations of your project?

The current limitations are that the platform still needs more testing with real production-scale data, more advanced correlation rules, stronger RBAC, and more validation of AI-generated remediation.

Also, the system should be extended with more integrations, such as threat intelligence feeds, ticketing systems, and enterprise identity providers.

Q48. What future improvements would you add?

I would improve the platform by adding advanced machine learning anomaly detection, stronger RBAC, more threat intelligence sources, integration with ticketing systems like Jira, Kubernetes-native deployment, and more production-grade high availability.

I would also improve the AI layer with better RAG, safer playbook templates, and stronger policy enforcement.

Q49. Can your project scale?

Yes, the architecture is modular. Each layer can be scaled separately.

For example, Elasticsearch can be moved to a cluster, the backend can be containerized and replicated, and collectors can be deployed on multiple machines.

The current version proves the architecture, and future versions can evolve toward a more distributed production deployment.

12. Tricky Jury Questions

Q50. Is this project a SIEM, SOAR, or SOC platform?

It combines elements of the three.

The SIEM part is represented by log collection, Elasticsearch, and Kibana.

The SOAR part is represented by playbook generation, approval, Ansible execution, and remediation workflows.

The SOC platform aspect is the complete operational workflow that connects monitoring, detection, investigation, response, and reporting.

Q51. Why not just use Wazuh or Elastic Security directly?

Wazuh and Elastic Security are powerful tools, but my project focuses on building a custom intelligence and automation layer on top of collected data.

The objective is to integrate multiple sources, apply custom correlation, create investigations, use AI for explanation and playbook generation, and control remediation through approval workflows.

So I am not replacing these tools; I am extending them into a complete SOC workflow.

Q52. What makes your project intelligent?

The intelligence comes from several layers: enrichment, deduplication, correlation, risk scoring, AI-generated investigation summaries, attack narrative generation, and dynamic playbook generation.

The platform does not only display raw alerts. It interprets them and helps the analyst decide what to do.

Q53. What happens if the AI gives a wrong answer?

The platform is designed to handle that risk. AI output is not executed directly.

The backend validates generated playbooks, applies safety checks, and requires approval. The analyst can reject or modify the proposed action.

So AI is used as decision support, not as an autonomous authority.

Q54. What is the difference between automation and controlled automation?

Automation means the system can perform tasks automatically.

Controlled automation means the system performs tasks only after validation, approval, safety checks, execution logging, and verification.

In cybersecurity, controlled automation is safer because wrong actions can affect production systems.

Q55. What is your biggest contribution?

My biggest contribution is connecting the complete SOC lifecycle into one platform: visibility, detection, enrichment, correlation, investigation, AI assistance, remediation, approval, verification, and archiving.

The project transforms disconnected alerts into controlled and explainable security operations.

13. Best Short Answers to Memorize

Alert vs Incident vs Investigation

An alert is a single event. An incident is a correlated security case. An investigation is the detailed analysis and response preparation for that incident.

Why AI?

AI helps explain incidents, summarize evidence, evaluate risk, and generate remediation suggestions, but it does not replace human validation.

Why Ansible?

Ansible allows agentless and auditable remediation through playbooks, which makes it suitable for controlled SOC automation.

Why Elasticsearch internal?

Because Elasticsearch contains sensitive logs and security data. It must not be exposed publicly.

Main project value

The platform moves from raw alerts to actionable intelligence and controlled remediation.

Convince us answer

This project is valuable because it does not stop at collecting logs or showing dashboards. It creates a complete SOC workflow.

It collects events from multiple layers, normalizes and enriches them, correlates alerts into meaningful incidents, creates investigations, uses AI to explain and propose actions, and executes remediation only through controlled approval and verification.

So the platform improves visibility, reduces alert fatigue, accelerates investigation, and makes response safer and more auditable.

Final Reminder

Your safest defense strategy is to explain the project as a logical chain:

Collect data -> normalize it -> enrich it -> correlate alerts into incidents -> investigate with context -> ask AI for assistance -> validate the proposed playbook -> approve -> execute -> verify -> archive.